

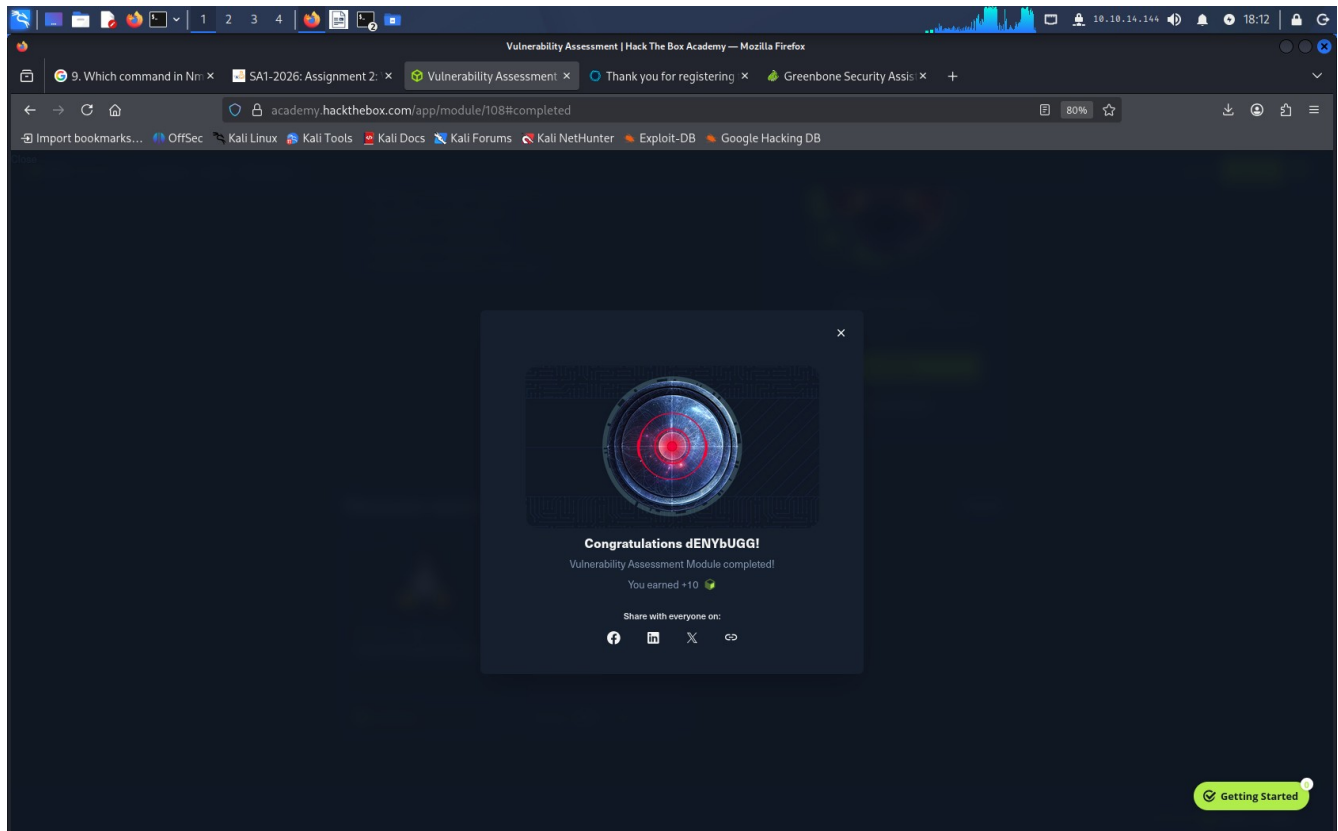
**NAME: Alex Mbogo**  
**GMAIL: evansnjiru5@gmail.com**  
**ADMISSION NUMBER: ADC-CSS02-25064**

## **Module: Vulnerability Assessment**

Module link

<https://academy.hackthebox.com/achievement/1378833/108>

Module Badge



## 1:1 Security Assessments

### Comparison of Security Assessments

| Feature         | Vulnerability Assessment                                                     | Penetration Test                                                                  |
|-----------------|------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|
| Primary Goal    | Identify and confirm vulnerabilities based on security standards/checklists. | Simulate a cyber attack to see if and how a network can be penetrated.            |
| Methodology     | Analyzing compliance with standards (e.g., using a checklist).               | Conducting actions a threat actor would perform to test if exploits are possible. |
| Ideal Candidate | All organizations, especially those with lower security maturity.            | Organizations with medium or high security maturity.                              |
| Outcome         | A report used to improve security by patching or mitigating risks.           | A detailed report showing if certain exploits are possible and how to fix them.   |

### Types of Penetration Tests

- **Black Box:** The tester has no knowledge of the network configuration. They must perform their own discovery.
- **Grey Box:** The tester has limited knowledge, equivalent to an average employee (e.g., a receptionist).
- **White Box:** The tester has full access to all systems, configurations, and source code.

### Specialized Roles

- **Network/Infrastructure Pentesters:** Focus on routers, firewalls, and servers; often use tools like Nessus (in non-evasive tests).
- **Application Pentesters:** Assess web apps, APIs, and mobile apps, often performing secure code reviews.
- **Physical Pentesters:** Test physical barriers (e.g., tailgating into a data center or crawling through vents).
- **Social Engineering Pentesters:** Test the "human element" via phishing, vishing, or impersonation.

### Compliance and Public Testing

- **Security Audits:** Unlike internal assessments, these are mandated requirements from outside agencies (like government or industry bodies).
  - *Example:* PCI-DSS compliance for any business accepting credit cards. Non-compliance results in fines or loss of payment processing abilities.
- **Bug Bounties:** Organizations invite the general public to find vulnerabilities in exchange for rewards. This is best for companies with high security maturity (like Microsoft or Apple) who have dedicated teams to triage reports.

### Red vs. Purple Teaming

| Feature     | Red Team Assessment             | Purple Team Assessment                       |
|-------------|---------------------------------|----------------------------------------------|
| Perspective | Evasive black box simulating an | A collaborative effort between offensive and |

|                 |                                                                    |                                                                          |
|-----------------|--------------------------------------------------------------------|--------------------------------------------------------------------------|
|                 | external threat actor.                                             | defensive teams.                                                         |
| Goal            | Achieve a specific end goal (e.g., accessing a critical database). | Improve network security through active feedback and cooperation.        |
| Scope           | Only reports vulnerabilities that led to the specific goal.        | Involves the blue team at every step to design and learn from campaigns. |
| The "Blue" Role | Acts as the target/defender being tested.                          | Provides active input and works alongside the red team to patch flaws.   |

## 1:2 Vulnerability Assessment

### Core Concepts

- Goal: To understand and categorize risks for "apparent issues" in an environment.
- Minimal Exploitation: Unlike a pentest, this process involves little to no exploitation. If done, it is only to confirm findings and rule out false positives.
- Remediation: A key output is providing specific steps to fix identified issues. Organizations are advised to test patches before deployment to avoid service disruptions.

### The Risk Equation

Threat + Vulnerability = Risk

- Vulnerability: A known weakness or bug (often tracked via MITRE's CVE database).
- Threat: The process or actor that amplifies the potential of a negative event.
- Risk: The actual potential for damage when a threat exploits a vulnerability.
- Exploit: The specific code or resource (found on sites like Exploit-db or GitHub) used to take advantage of a vulnerability.

### Scoring Severity (CVSS)

Vulnerabilities are rated from 0 to 10 using the Common Vulnerability Scoring System (CVSS).

Factors influencing the score include:

- Attack Vector: (Network, Local, Physical, etc.)
- Complexity: How difficult the attack is to execute.
- Privileges: Whether the attacker needs an account to succeed.
- Impact: The effect on Confidentiality, Integrity, and Availability (the CIA triad)

### Methodology (8 Steps)

1. Risk Identification/Analysis
2. Develop Scanning Policies
3. Identify Scan Types
4. Configure the Scan
5. Perform the Scan
6. Evaluate Risks
7. Interpret Results
8. Create a Remediation Plan

## 1:3 Assessment Standards

Organizations adhere to these standards to maintain accreditation and ensure operational security:

- **PCI DSS:** Applies to entities handling credit card data. It focuses on segmenting the Cardholder Data Environment (CDE) and conducting regular asset scanning.
- **HIPAA:** Designed to protect patient healthcare information. It necessitates risk assessments and the identification of vulnerabilities.
- **FISMA:** A standard for U.S. government operations requiring documentation of a vulnerability management program to ensure system integrity.
- **ISO 27001:** A global framework for managing information security through an Information Security Management System (ISMS), requiring periodic internal and external scans.

## Penetration Testing Methodology Standards

Standardized frameworks help ensure that penetration tests are consistent and comprehensive:

| Standard      | Focus Area            | Key Phases / Components                                                                                        |
|---------------|-----------------------|----------------------------------------------------------------------------------------------------------------|
| <b>PTES</b>   | General Methodology   | Covers the lifecycle from pre-engagement and intelligence gathering to vulnerability analysis and reporting.   |
| <b>OSSTMM</b> | Operational Security  | Focuses on five channels: Human, Physical, Wireless, Telecommunications, and Data Networks.                    |
| <b>NIST</b>   | Government/ Framework | Includes four main phases: Planning, Discovery, Attack, and Reporting.                                         |
| <b>OWASP</b>  | Application Security  | The primary standard for assessing web and mobile applications, such as the Web Security Testing Guide (WSTG). |

## Professional and Legal Requirements

Professional assessments must be governed by a specifically defined scope and a signed legal contract. This ensures that the testing is authorized and that the owners of the network are aware of the activities. A core principle of professional pentesting is to cause minimal harm to the environment. For instance, rather than removing sensitive data to prove a vulnerability, a tester might provide a screenshot of file metadata to demonstrate access without compromising the data itself

## 2:1 Vulnerability Scoring System

### Common Vulnerability Scoring System (CVSS)

#### 2:1:1 Microsoft DREAD Model

DREAD is a risk assessment system that uses a 10-point scale to evaluate five factors:

- **Damage Potential:** How much damage can be done?
- **Reproducibility:** How easy is it to repeat the attack?
- **Exploitability:** How much effort is required to launch the attack?
- **Affected Users:** How many people are impacted?
- **Discoverability:** How easy is it to find the vulnerability?

#### 2:1:2 CVSS Metric Groups

The CVSS (currently v3.1) is divided into three main groups to calculate a final severity score:

##### 1. Base Metric Group (Intrinsic Qualities)

These are constant over time and across different environments.

- **Exploitability Metrics:** Attack Vector (how), Attack Complexity (difficulty), Privileges Required, and User Interaction.
- **Impact Metrics (The CIA Triad):**
  - **Confidentiality:** Is data kept private? (High: Stealing encryption keys).
  - **Integrity:** Is data unaltered? (High: Modifying business files).
  - **Availability:** Is data accessible? (High: Total system downtime).

## 2. Temporal Metric Group (Evolution Over Time)

These change as the "outside world" reacts to the vulnerability.

- **Exploit Code Maturity:** Is there a "Functional" exploit available or just a "Proof-of-Concept"?
- **Remediation Level:** Is there an "Official Fix," a "Workaround," or is it "Unavailable"?
- **Report Confidence:** Is the vulnerability "Confirmed" by multiple sources?

## 3. Environmental Metric Group (Organizational Context)

These allow an organization to customize the score based on their specific needs.

- **Modified Base Metrics:** Adjusts the CIA impact values (Low, Medium, High) based on how critical that specific asset is to the business.

## 2:1:3 Open Vulnerability Assessment Language (OVAL)

OVAL is an international XML-based standard used to evaluate a system's state without needing to exploit it. It is a key component of NIST's SCAP (Security Content Automation Protocol).

- **The Three-Step Process:**
  1. **Identify** system configurations for testing.
  2. **Evaluate** the current state (Vulnerable, Non-compliant, Patched, etc.).
  3. **Disclose** results in a report.
- **Definition Classes:**
  1. **Vulnerability:** Identifies known bugs.
  2. **Compliance:** Checks if settings meet policy.
  3. **Inventory:** Checks if specific software is installed.
  4. **Patch:** Checks if the correct updates are applied.
- **ID Format:** oval:[Organization]:[Type]:[Value] (e.g., oval:org.mitre.oval:obj:1116).

## 2:1:4 Common Vulnerabilities and Exposures (CVE)

A CVE is a unique identifier assigned to a specific security flaw to provide a standardized "dictionary" for IT professionals.

- **Assignment Criteria:** To get a CVE ID, a flaw must be independently fixable, affect only one codebase, and be acknowledged by the vendor.
- **The CVE Lifecycle:**
  - Starts with a researcher identifying a new vulnerability and contacting the vendor (Responsible Disclosure).

- Moves through a CVE Numbering Authority (CNA) or the CVE Web Form for ID assignment.
- Ends with Public Disclosure once a patch is ready or the vendor is informed, preventing "Zero-Day" exploitation by malicious actors.

### Notable CVE Examples

- **CVE-2020-5902 (F5 BIG-IP):** An unauthenticated remote code execution (RCE) flaw allowing full system takeover.
- **CVE-2021-34527 (PrintNightmare):** An authenticated RCE in the Windows Print Spooler. It is high-risk because it allows attackers to gain full control of domain controllers.

### Responsible Disclosure vs. Zero-Day

- **Responsible Disclosure:** A researcher informs the vendor privately, allowing them to create a patch *before* the flaw is made public.
- **Zero-Day (0-day):** A vulnerability that is exploited by threat actors before the vendor is aware of it or has a patch available.

### 3:1 Nessus

is an industry-standard vulnerability scanner used to identify security flaws, misconfigurations, and missing patches across a network

#### 3:1:1 Getting started with Nessus

- Downloading Nessus <https://www.tenable.com/downloads/nessus?loginAttempted=true>
- Requesting Free License <https://www.tenable.com/products/nessus/activation-code>
- Install Package : `dpkg -i Nessus-8.15.1-ubuntu910_amd64.deb`
- Starting Nessus: `sudo systemctl start nessusd.service`
- Accessing Nessus :`https://localhost:8834`

#### 3:1:2 NESSUS

Nessus enables targeted vulnerability assessments by allowing users to select from various scan templates, including Host Discovery, Basic Network Scans, and specialized tests for Malware or Web Applications. Advanced settings allow for, among other things, enabling safe checks, managing scan speed based on network congestion, and randomizing the order of target IP addresses.

Nessus scan is configured by clicking New Scan, and selecting a scan type

#### New Scan

we have options for a basic Host Discovery scan to identify live hosts/open ports or a variety of scan types such as the Basic Network Scan, Advanced Scan, Malware Scan, Web Application Tests, as well as scans targeted at specific CVEs and audit & compliance standards. A description of each scan type can be found ,

#### Discovery

## Assessment

Under the Assessment category, web application scanning can also be enabled if required, and a custom user agent and various other web application scanning options can be specified (e.g., a URL for Remote File Inclusion (RFI) testing)

## Advanced

On the Advanced tab, safe checks are enabled by default. This prevents Nessus from running checks that may negatively impact the target device or network. We can also choose to slow or throttle the scan if Nessus detects any network congestion, stop attempting to scan any hosts that become unresponsive, and even choose to have Nessus scan our target IP list in random order.

### 1. Scan Policies

**Scan policies are custom templates that allow you to save specific configurations for reuse.**

- **Purpose:** Create targeted scans (e.g., slow/evasive, web-focused, or client-specific).
- **Customization:** You can start with a "Basic Network Scan" and modify it, or use an **Advanced Scan** to build a policy from scratch with no pre-configured recommendations.
- **Management:** Policies can be imported/exported between different Nessus scanners and appear under the **User Defined** tab when starting a new scan.

### 2. Nessus Plugins & Rules

Nessus uses plugins written in **NASL** to detect vulnerabilities.

- **Volume:** Over 145,000 plugins covering nearly 60,000 CVEs.
- **Plugin Rules:** Used to manage false positives or noisy results.
  - *Example:* If a service like Microsoft DirectAccess shows "insecure ciphers" by design, you can create a rule using the Plugin ID and Host to "Hide this result" from reports while keeping the detection active for other targets.

### 3. Credentialed Scanning

Using credentials allows Nessus to perform deep local inspections of the operating system and installed applications.

- **Windows:** Supports Password, Kerberos, LM/NTLM hashes.
- **Linux/Unix:** Supports SSH passwords, public keys, certificates, or Kerberos.
- **Databases:** Can authenticate into SQL Server, MySQL, Oracle, MongoDB, etc., to check for internal misconfigurations.
- **Plaintext Services:** Can perform logins for web applications (HTTP forms), FTP, and Telnet.

### 4. Verification

After running a scan, always check the Nessus output to confirm Authentication Success. If credentials fail, the scan reverts to an unauthenticated (remote) state, which is significantly less thorough.

#### 1. Report Formats

- **PDF/HTML:** Best for humans. You can choose an Executive Summary (high-level stats) or a Custom Report (deep technical details).

- *Pro Tip:* These reports contain links directly to the Tenable database for remediation steps.
- **CSV:** Best for data. Use this if you need to feed results into Splunk, Excel, or a custom remediation tracker used by internal teams.
- **Professional Standard:** Never give a raw Nessus report as your final deliverable. It should only be an appendix or supplementary data to a manually written, verified report.

## 2. Technical Exports

If you need to move the scan data between systems or into automation scripts:

- **.nessus (XML):** Contains the scan settings and raw plugin outputs.
- **.db:** A more complete package including the Audit Trail and Knowledge Base (KB).
- **EyeWitness Integration:** You can export the raw results into tools like EyeWitness to automatically take screenshots of every web application Nessus discovered.

## 3. Automation via CLI

You don't always have to use the GUI. Tools like `nessus-report-downloader` use the Nessus REST API to pull reports directly to your terminal. This is vital for large-scale assessments where you might be managing dozens of scans at once.

Vulnerability scanning is a powerful but intrusive process. To avoid crashing systems or flooding networks, you must follow these best practices for

### safe and effective scanning

#### 1. Mitigating Network & Host Issues

- **Firewall Interference:** If a firewall makes a host appear "dead" or shows all ports as open, disable the "**Ping the remote host**" option in an Advanced Scan. This forces Nessus to scan regardless of ICMP (ping) responses.
- **Rate Limiting:** On sensitive or high-load networks, adjust **Performance Options**. Specifically, lower the "**Max Concurrent Checks Per Host**" to reduce the strain on the target's CPU and memory.
- **Fragile Systems:** Always exclude **printers** and **legacy systems** unless necessary. Use the `nessusd.rules` file to hard-code exclusions at the scanner level.
- **Safe Checks:** Always keep "**Safe Checks**" enabled. This prevents Nessus from running dangerous plugins (like **Denial of Service** checks) that could crash a service or a network daemon.

#### 2. Measuring Network Impact

Scanning consumes significant bandwidth and generates high packet counts. You can monitor this in Linux using `vnstat`:

- **Idle Traffic:** Minimal (measured in bits/s).
- **Active Scan Traffic:** Can jump to hundreds of kilobits per second (kbit/s) and thousands of packets per second for just a single host.
- **Consequence:** On low-bandwidth links or congested networks, an unoptimized scan can cause legitimate business traffic to drop or latency to spike.

### 3. Communication & Planning

- **Stakeholder Alerting:** Always notify IT staff and clients before starting.
- **Scheduling:** Perform scans against high-availability or sensitive hosts outside of business hours.
- **Logging:** Keep detailed logs of your scanning window. If a server crashes, you need to be able to prove whether or not your scan was the cause.

**Critical Rule:** Never perform Denial of Service (DoS) checks unless explicitly requested and documented in the legal scope of the assessment.

#### SCENARIO:

You Have been contracted by the company Inlanefreight to perform an internal vulnerability assessment against one of their servers. They have asked for a cursory assessment to be performed to identify any significant vulnerabilities as they do not have the budget for a full-scale penetration test this year. The results of this vulnerability assessment may enable the CISO to push for additional funding from the Board of Directors to perform more in-depth security testing.

The target server is a Windows Server host used as a development server.

## Requirements

Navigate to the web interface at the end of this section and log in with the provided credentials.

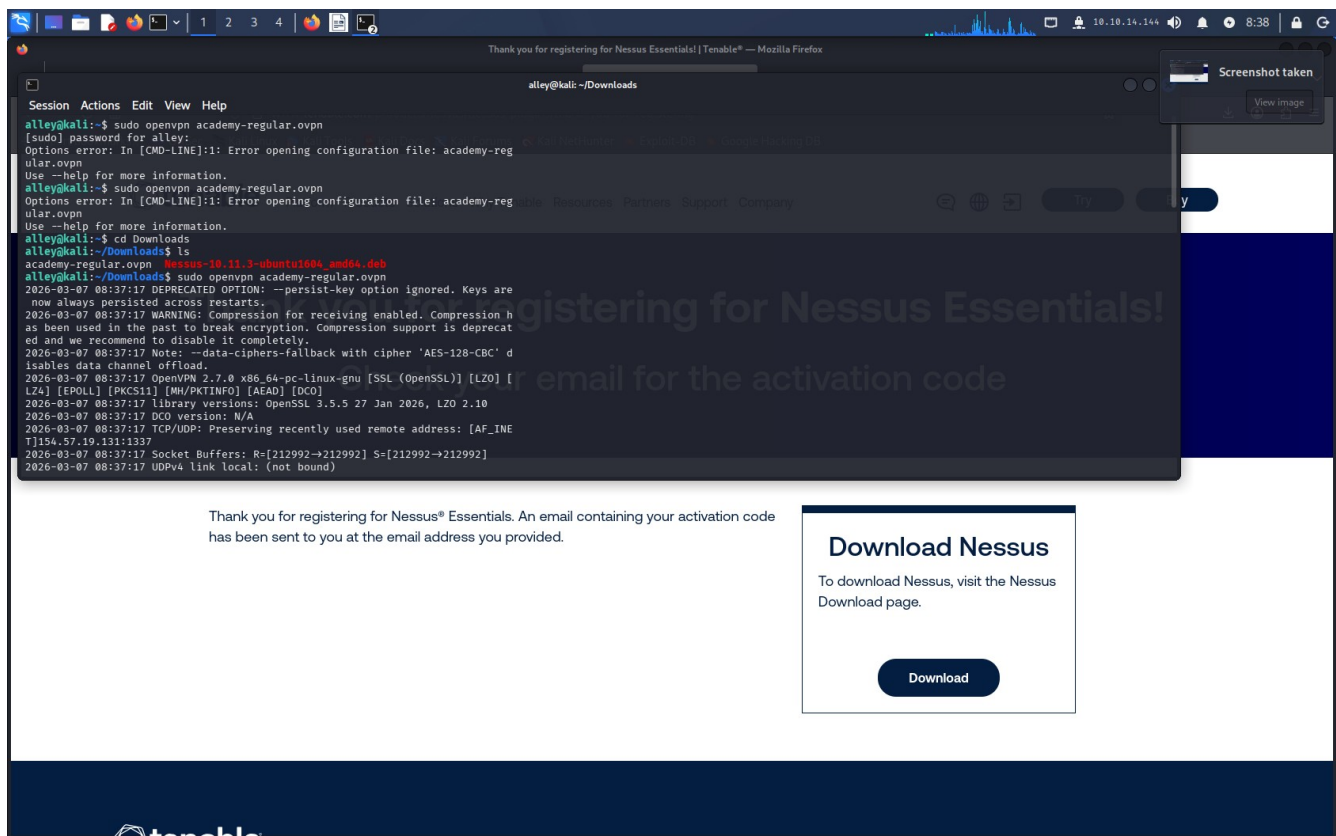
Once logged in, perform a BASIC NETWORK SCAN (modify the scan template to scan ALL ports, leave all other options the same) against the target: 172.16.16.100. Additionally, set up the scan to be authenticated using administrator:Academy\_VA\_adm1! as the credentials.

**Target: 172.16.16.100**

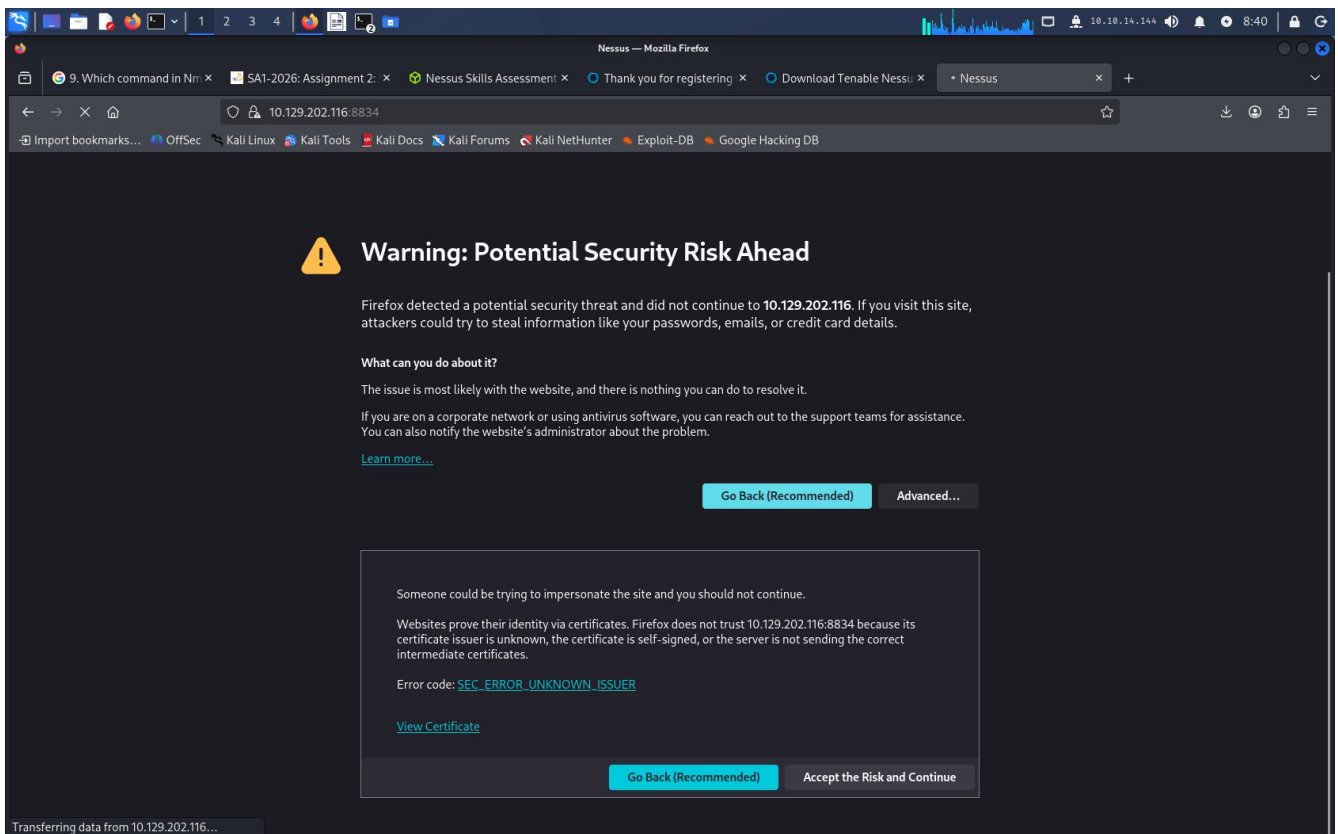
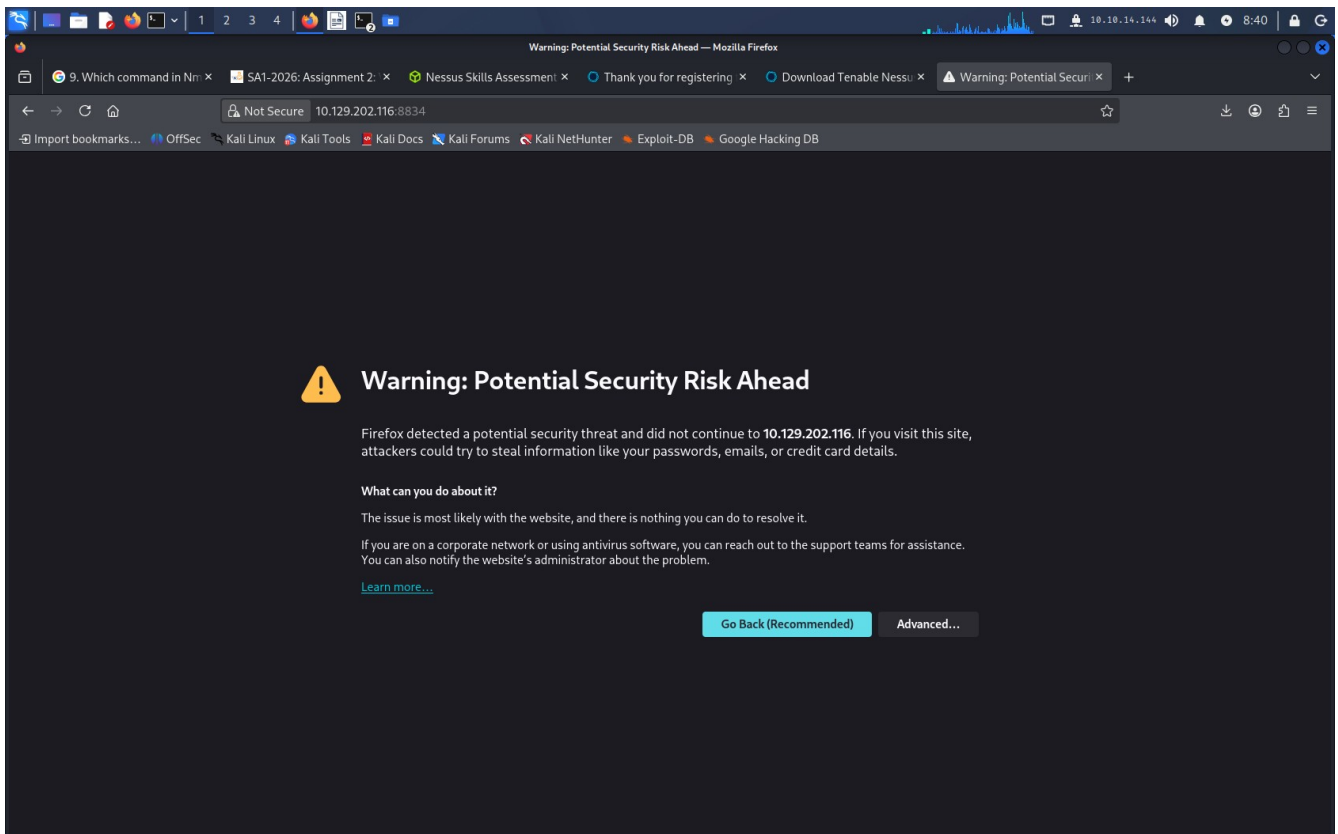
**Credentials are: htb-student:[HTB @cademy student!](#)**

Step 1:

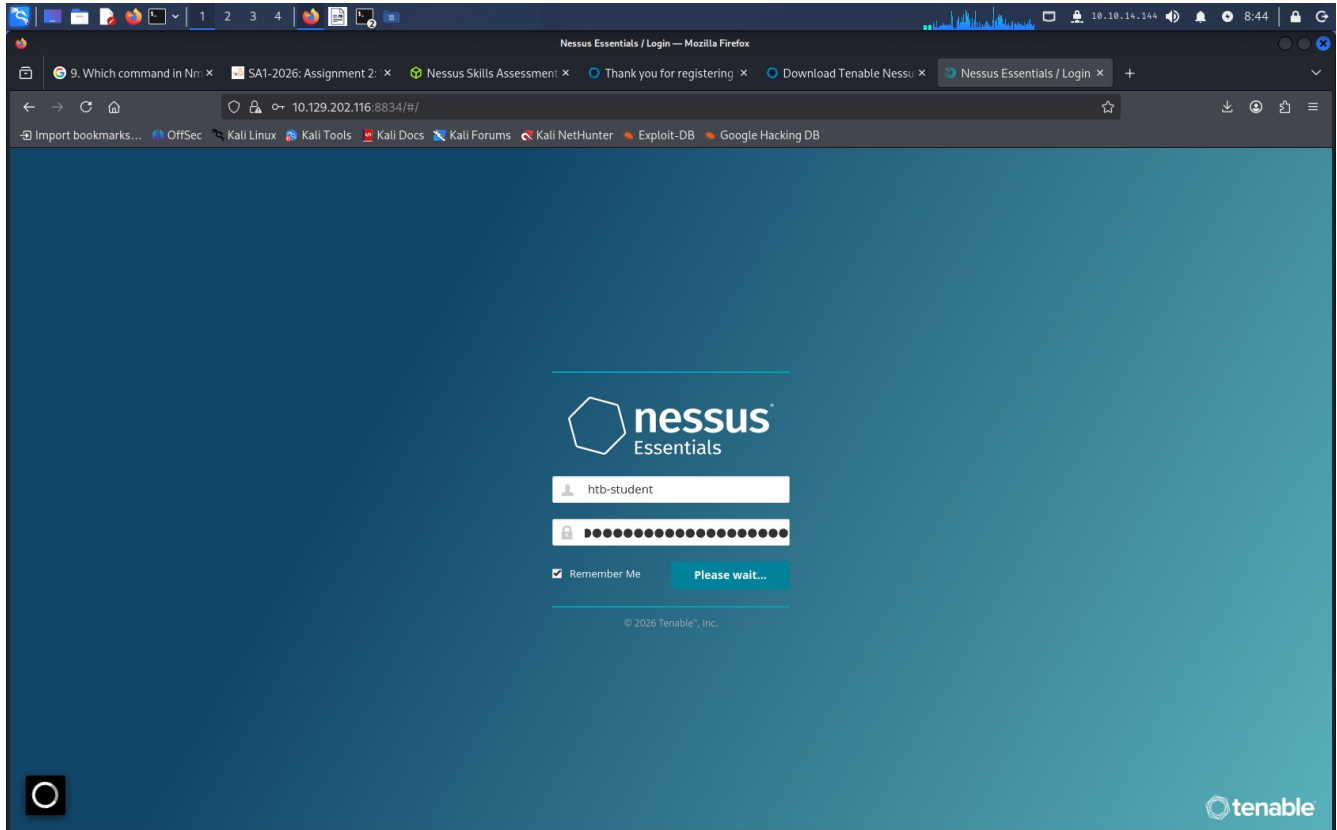
Connect to the HTB network using: `sudo openvpn academy-regular.ovpn`



Step2: open your local browser and go to <https://10.129.202.116:8834>

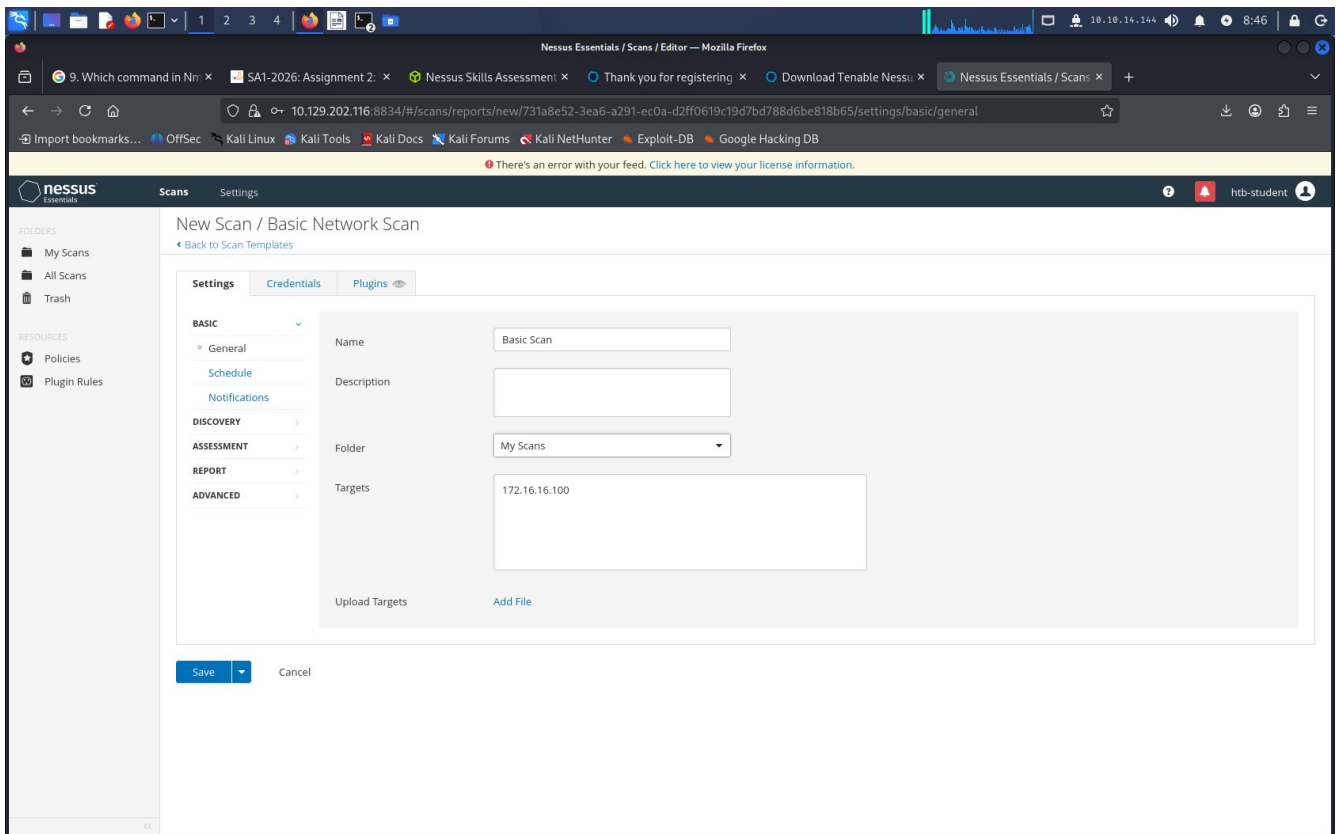


Credentials are: `htb-student:HTB @cademy student!`

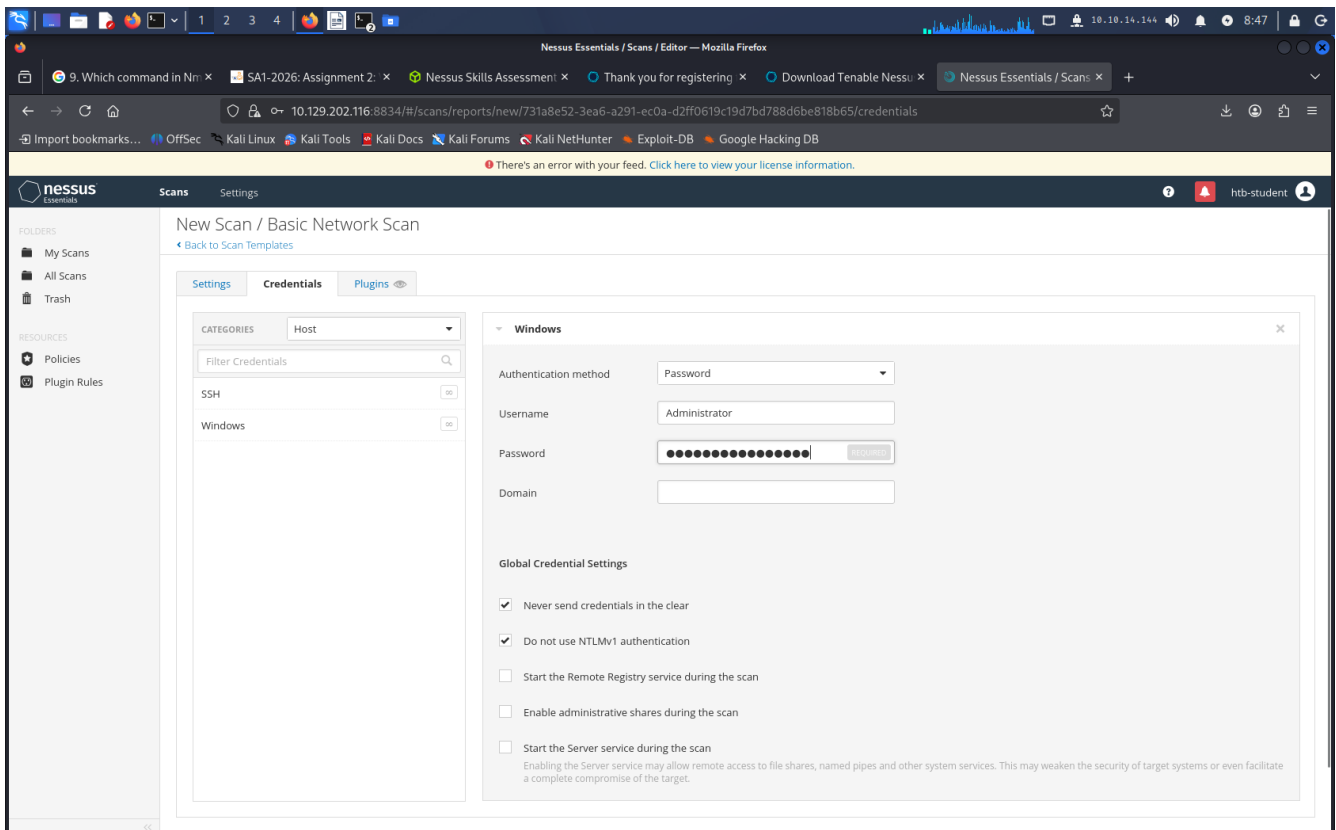


**What is the name of one of the accessible SMB shares from the authenticated Windows scan?  
(One word)**

*wsus*



set up the scan to be authenticated using administrator:Academy\_VA\_adm1!



Nessus Essentials / Folders / View Scan — Mozilla Firefox

9. Which command in Nmap... SAI-2026: Assignment 2... Nessus Skills Assessment... Thank you for registering... Question 1 +1 streak flam... Nessus Essentials / Folders... Screenshot\_2026-03-07\_08... 10.10.14.144 9:06

10.129.202.116:8834/#/scans/reports/21/vulnerabilities/10395

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

There's an error with your feed. Click here to view your license information.

nessus Essentials Scans Settings htb-student

FOLDERS

- My Scans 1
- All Scans
- Trash

RESOURCES

- Policies
- Plugin Rules

Windows\_basic\_authed / Plugin #10395

Configure Audit Trail Launch Report Export

Hosts 1 Vulnerabilities 349 Remediations 11 VPR Top Threats History 1

INFO Microsoft Windows SMB Shares Enumeration

Description

By connecting to the remote host, Nessus was able to enumerate the network share names.

Output

Here are the SMB shares available on the remote host when logged in as administrator:

- ADMIN\$
- IPC\$
- Private Docs
- w\$us

Port 4 Hosts

|                  |               |
|------------------|---------------|
| 445 / tcp / cifs | 172.16.16.100 |
|------------------|---------------|

Plugin Details

Severity: Info  
ID: 10395  
Version: 1.48  
Type: local  
Family: Windows  
Published: May 9, 2000  
Modified: February 1, 2022

Risk Information

Risk Factor: None

Vulnerability Information

Asset Inventory: True

Nessus Skills Assessment | Hack The Box Academy — Mozilla Firefox

9. Which command in Nmap... SAI-2026: Assignment 2... Nessus Skills Assessment... Thank you for registering... Question 1 +1 streak flam... Nessus Essentials / Folders... Screenshot\_2026-03-07\_08... 10.10.14.144 9:03

academy.hackthebox.com/app/module/108/section/1233

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

HTB ACADEMY Dashboard Library Resources

Time left: 77 min(s)

Target(s)

10.129.202.116 (ACADEMY-VA-SCAN01)

Enable step-by-step solutions PRO

Question 1

What is the name of one of the accessible SMB shares from the authenticated Windows scan? (One word)

Authenticate to 10.129.202.116 (ACADEMY-VA-SCAN01), with user "htb-student" and password "HTB\_@cademy\_student!"

w\$us

Question 2

What was the target for the authenticated scan?

Unprivileged Access

Submit

Weekly Goal Started

Every week achieve the Weekly Goal by reaching 30 Points. Keep your Streak alive and win special rewards.

10/30 points

Getting Started

Previous Section 12 / 17 Next

What was the target for the authenticated scan?

172.16.16.100

The screenshot shows the Nessus Essentials interface for a scan titled "Windows\_basic\_authed / 172.16.16.100". The left sidebar contains "FOLDERS" (My Scans, All Scans, Trash) and "RESOURCES" (Policies, Plugin Rules). The main area displays a table of vulnerabilities. The table has columns for "Sev", "Score", "Name", "Family", and "Count". The vulnerabilities listed are:

| Sev      | Score | Name                                                                       | Family                        | Count |
|----------|-------|----------------------------------------------------------------------------|-------------------------------|-------|
| CRITICAL | 10.0  | Apache Log4j Unsupported Version Detection                                 | Misc.                         | 9     |
| CRITICAL | 10.0  | Oracle Java JRE Unsupported Version Detection                              | Windows                       | 1     |
| CRITICAL | 10.0  | Oracle WebLogic Server Multiple Vulnerabilities (April 2017 CPU)           | Misc.                         | 1     |
| CRITICAL | 10.0  | Oracle WebLogic Server Multiple Vulnerabilities (July 2017 CPU)            | Misc.                         | 1     |
| CRITICAL | 10.0  | Unsupported Web Server Detection                                           | Web Servers                   | 1     |
| CRITICAL | 9.9   | Oracle WebLogic Server Multiple Vulnerabilities (October 2017 CPU)         | Misc.                         | 1     |
| CRITICAL | 9.8   | Apache Log4j 1.x Multiple Vulnerabilities                                  | Misc.                         | 9     |
| CRITICAL | 9.8   | Jenkins LTS < 2.303.3 / Jenkins weekly < 2.319 Multiple Vulnerabilities    | CGI abuses                    | 1     |
| CRITICAL | 9.8   | KB4022715: Windows 10 Version 1607 and Windows Server 2016 June 2017 C...  | Windows : Microsoft Bulletins | 1     |
| CRITICAL | 9.8   | KB4025339: Windows 10 Version 1607 and Windows Server 2016 July 2017 Cu... | Windows : Microsoft Bulletins | 1     |
| CRITICAL | 9.8   | KB4041691: Windows 10 Version 1607 and Windows Server 2016 October 201...  | Windows : Microsoft Bulletins | 1     |
| CRITICAL | 9.8   | KB4457131: Windows 10 Version 1607 and Windows Server 2016 September ...   | Windows : Microsoft Bulletins | 1     |
| CRITICAL | 9.8   | KB4467691: Windows 10 Version 1607 and Windows Server 2016 November 2...   | Windows : Microsoft Bulletins | 1     |

On the right, the "Host Details" section shows:

- IP: 172.16.16.100
- MAC: 00:50:56:B9:80:5D
- OS: Microsoft Windows Server 2016 Standard
- Start: 2022-02-12 at 11:54 PM
- End: 2022-02-13 at 12:17 AM
- Elapsed: 23 minutes
- KB: Download

The "Vulnerabilities" section on the right features a donut chart showing the distribution of vulnerability severity levels: Critical (red), High (orange), Medium (yellow), Low (green), and Info (blue).

What is the plugin ID of the highest criticality vulnerability for the Windows authenticated scan?

156032

The screenshot displays the Nessus Essentials interface in a web browser. The main content area shows a vulnerability report for 'Windows\_basic\_authed / Plugin #156032'. The report is marked as 'CRITICAL' and is titled 'Apache Log4j Unsupported Version Detection'. The description explains that the installed version of Apache Log4j is no longer supported, posing a security risk. The solution is to upgrade to a supported version. The output section shows the path to the installed version (1.2.15) and a table of open ports (445/tcp) on host 172.16.16.100.

**Vulnerabilities** 349

**CRITICAL** Apache Log4j Unsupported Version Detection

**Description**  
According to its self-reported version number, the installation of Apache Log4j on the remote host is no longer supported. Log4j reached its end of life prior to 2016.

Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it is likely to contain security vulnerabilities.

**Solution**  
Upgrade to a version of Apache Log4j that is currently supported.

Upgrading to the latest versions for Apache Log4j is highly recommended as intermediate versions / patches have known high severity vulnerabilities and the vendor is updating their advisories often as new research and knowledge about the impact of Log4j is discovered. Refer to <https://logging.apache.org/log4j/2.x/security.html> for the latest versions.

**See Also**  
<http://www.nessus.org/u?59f655a2>

**Output**

```
Path : C:\Oracle\Middleware\wlsrver_10.3\samples\server\examples\src\examples\webapp\pubsub\stock\stockEar\APP-INF\lib\log4j-1.2.15.jar
Installed version : 1.2.15
```

| Port             | Hosts         |
|------------------|---------------|
| 445 / tcp / cifs | 172.16.16.100 |

**Plugin Details**

Severity: Critical  
ID: 156032  
Version: 1.2  
Type: local  
Family: Misc.  
Published: December 13, 2021  
Modified: December 19, 2021

**Risk Information**

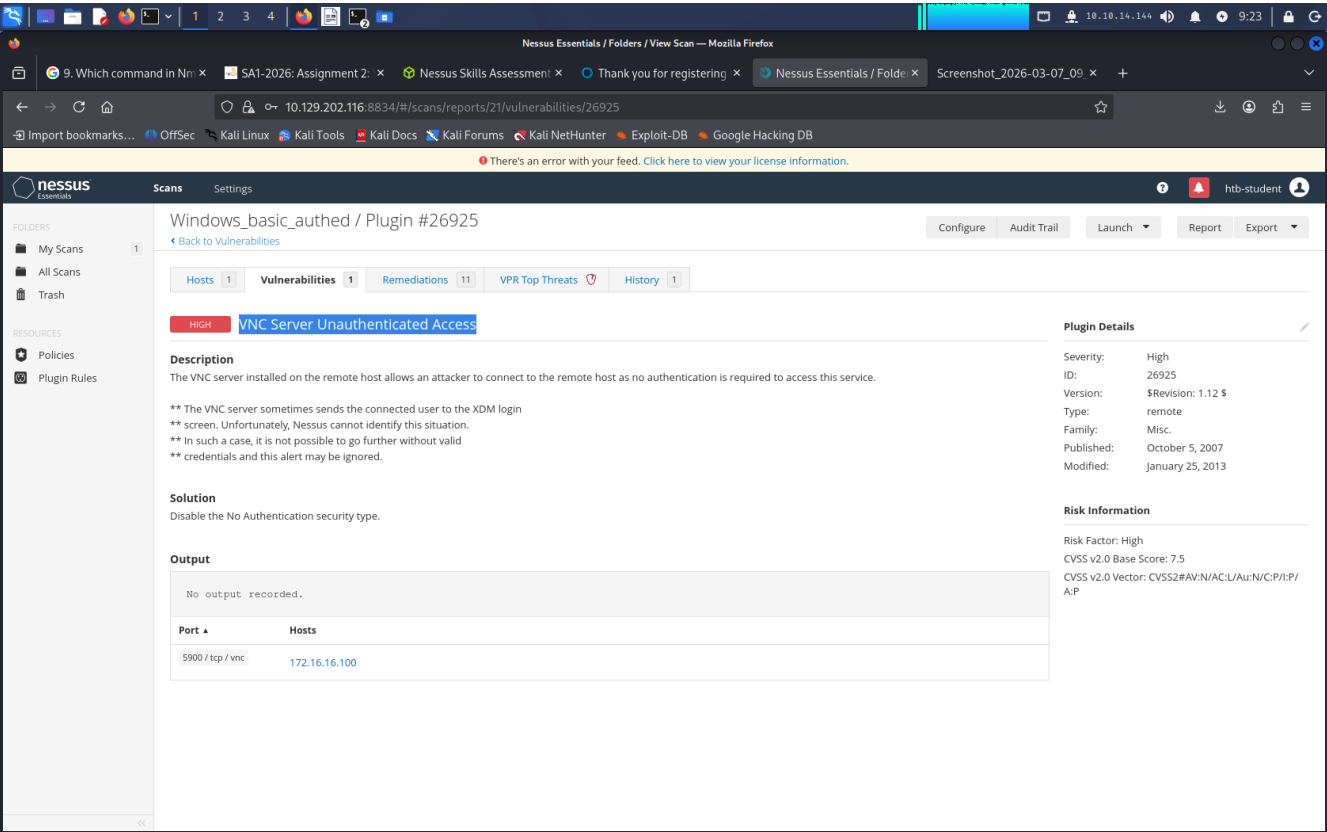
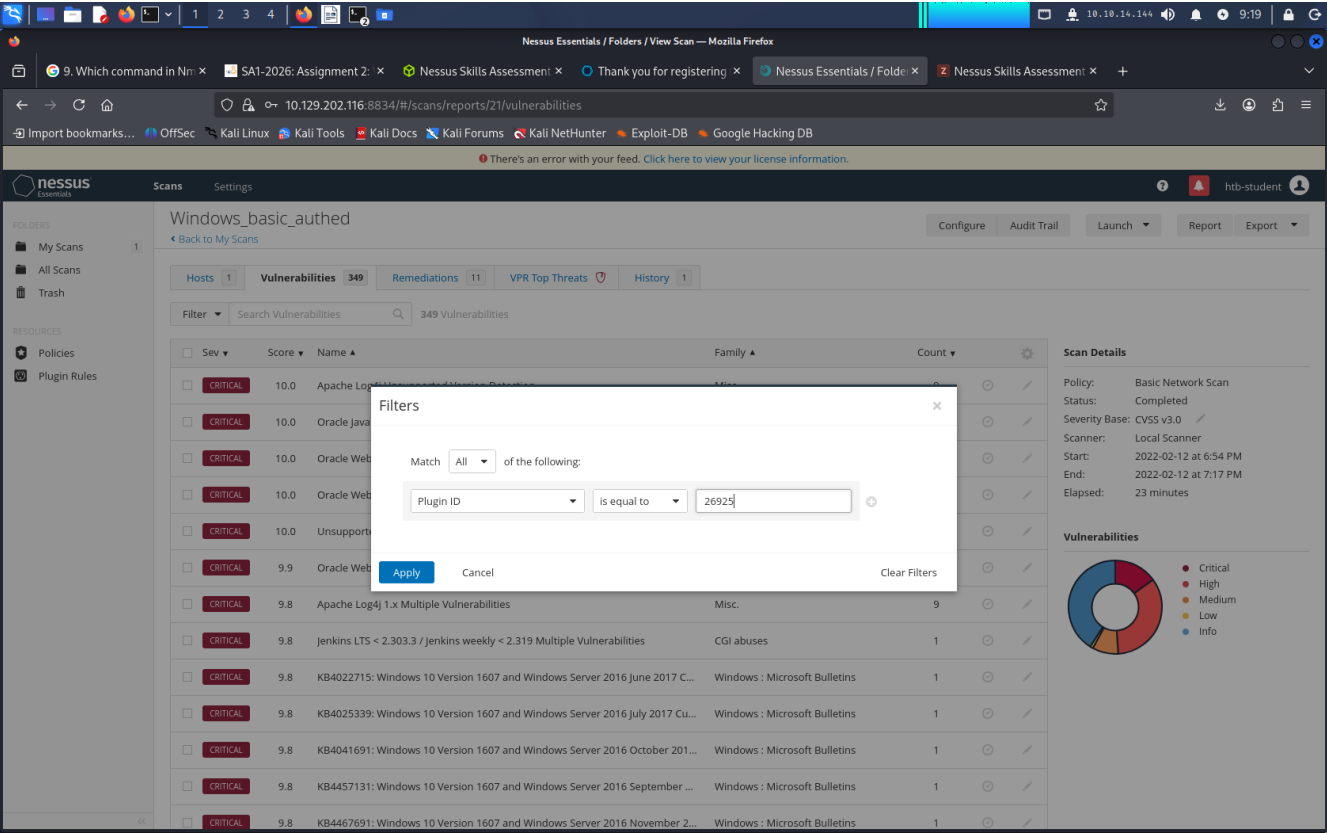
Risk Factor: Critical  
**CVSS v3.0 Base Score 10.0**  
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H  
CVSS v2.0 Base Score: 10.0  
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

**Vulnerability Information**

CPE: cpe:/a:apache:log4j  
Unsupported by vendor: true

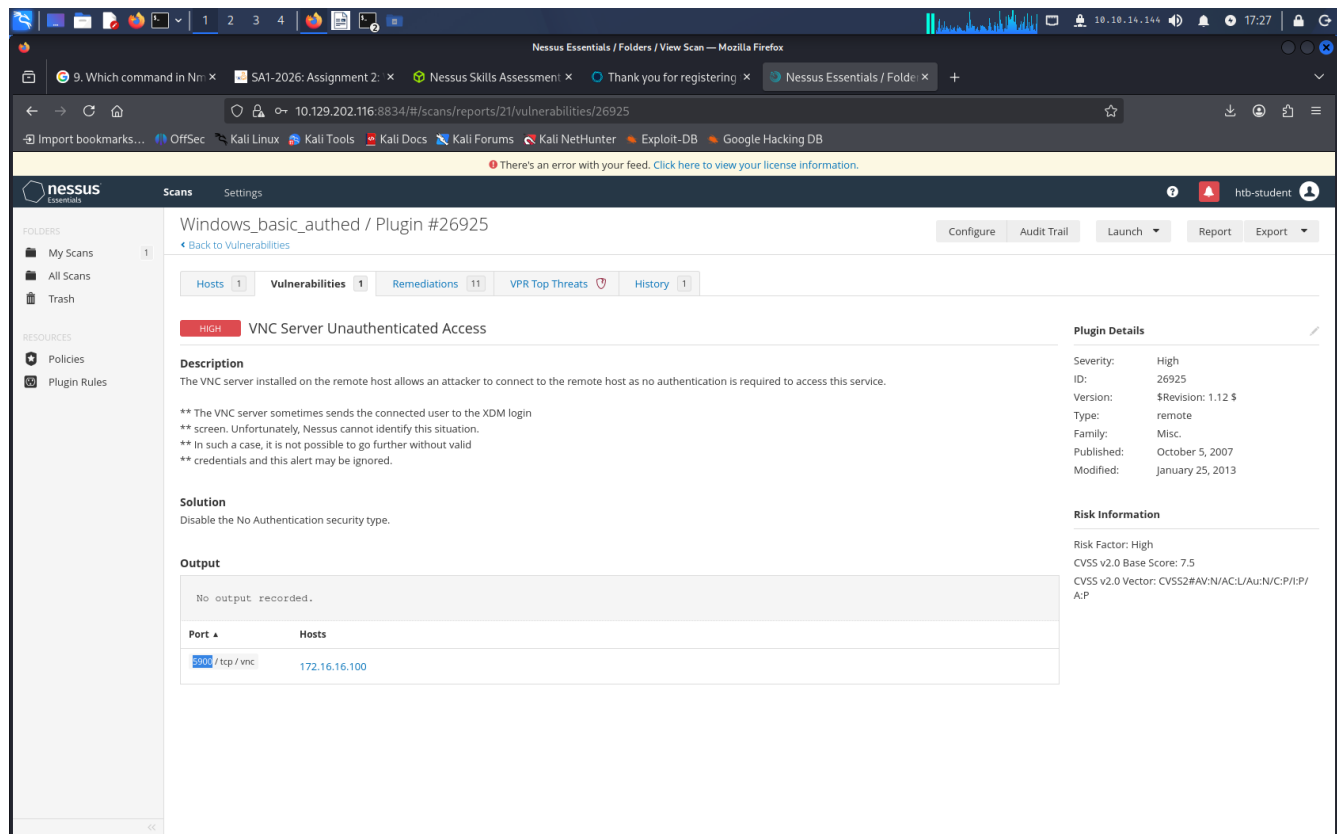
**What is the name of the vulnerability with plugin ID 26925 from the Windows authenticated scan? (Case sensitive)**

# VNC Server Unauthenticated Access



## What port is the VNC server running on in the authenticated Windows scan?

5900



### 4.1 OpenVAS

OpenVAS, by Greenbone Networks, is a publicly available vulnerability scanner. Greenbone Networks has an entire Vulnerability Manager, part of which is the OpenVAS scanner. Greenbone's Vulnerability Manager is also open to the public and free to use. OpenVAS has the capabilities to perform network scans, including authenticated and unauthenticated testing.

Greenbone Security Assistant login page with fields for username and password, and a 'Sign In' button.

#### Installing Package

```
dENYbUGG@htb[/htb]$ sudo apt-get update && apt-get -y full-upgrade
```

```
dENYbUGG@htb[/htb]$ sudo apt-get install gvm && openvas
```

```
dENYbUGG@htb[/htb]$ gvm-setup
```

#### Starting OpenVas

```
dENYbUGG@htb[/htb]$ gvm-start
```

## 1. Setup Targets

- Navigate to **Configuration > Targets**.
- Define the host IP (Windows: 172.16.16.100 | Linux: 172.16.16.160).
- Configure the Alive Test (Ping) to ensure the host is reachable.

## 2. Add Credentials

- Authenticated scans provide deeper results.
- **Windows:** administrator : Academy\_VA\_adm1!
- **Linux:** htb-student\_adm : HTB\_@cademy\_student!

## 3. Select Scan Configuration

- **Full and Fast:** The recommended "safest" and most intelligent option for general vulnerability testing.
- **Discovery/Base:** Used for enumeration only (no vulnerability checking).
- **System Discovery:** Identifies OS and hardware details.

## 4. Create and Run Task

- Navigate to the Scans tab and click the Wizard icon.
- Link your Target to the Scan Configuration.
- Launch the scan (typically takes 30–120 minutes; monitor vulnerabilities in real-time as they appear).

## Exporting The Results

OpenVAS provides the scan results in a report that can be accessed when you are on the Scans page .

Once you click the report, you can view the scan results and operating system information, open ports, services, etc., in other tabs in the scan report.

## Exporting Formats

There are various export formats for reporting purposes, including XML, CSV, PDF, ITG, and TXT. If you choose to export your report out as an XML, you can leverage various XML parsers to view the data in an easier to read format.

```
dENYbUGG@htb[/htb]$ python3 -m openvasreporting -i report-2bf466b5-627d-4659-bea6-1758b43235b1.xml -f xlsx
```

## SCENARIO

You have been contracted by the company Inlanefreight to perform an internal vulnerability assessment against one of their servers. They have asked for a cursory assessment to be performed to identify any significant vulnerabilities as they do not have the budget for a full-scale penetration test this year. The results of this vulnerability assessment may enable the CISO to push for additional funding from the Board of Directors to perform more in-depth security testing.

The target server is a Linux Server host.

## Requirements

Navigate to the OpenVAS web interface at the server below and log in with the provided credentials.

Once logged in, create a new task with the OpenVAS Default Scanner and use the Full and Fast config against the target: 172.16.16.160. Additionally, ensure you have the scan set up to run as an authenticated user using the credentials: root:HTB\_@cademy\_admin!.

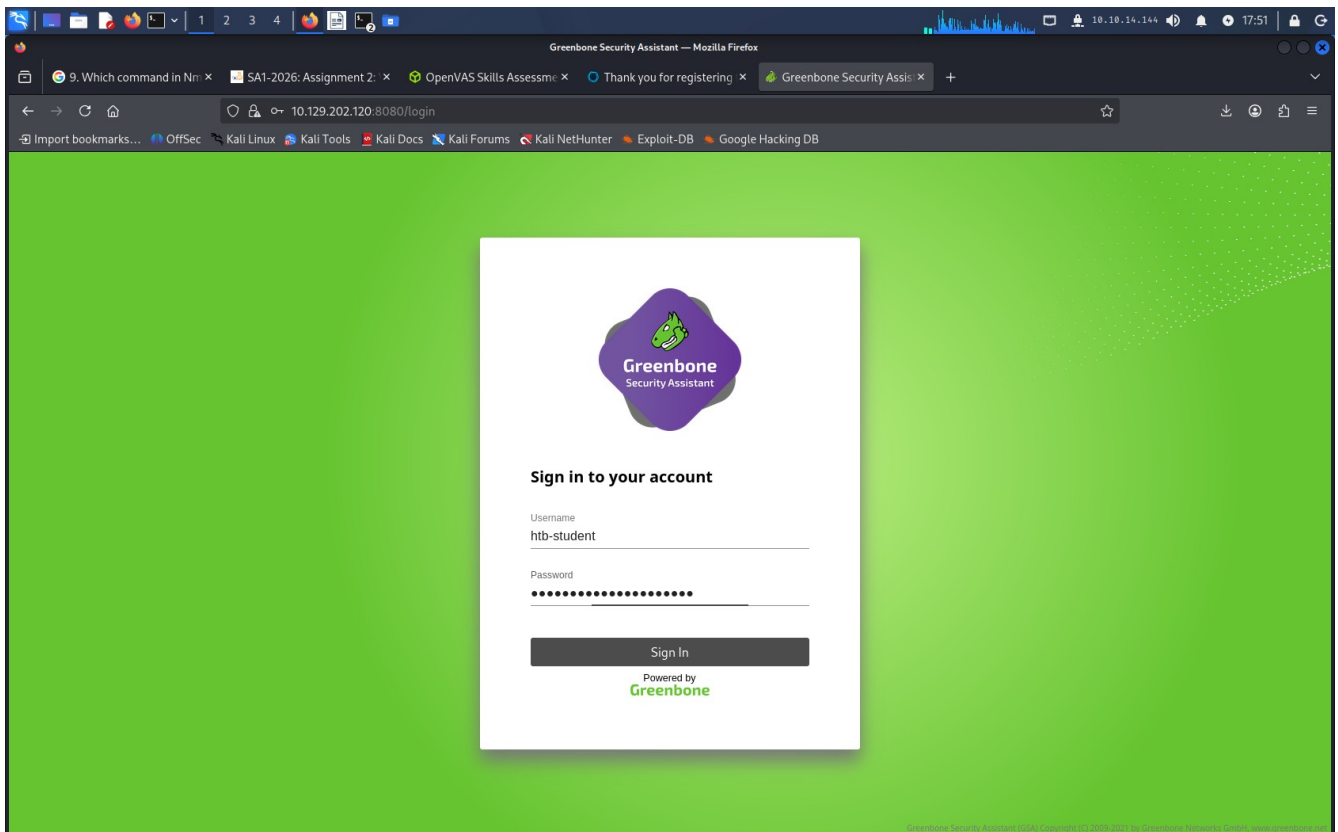
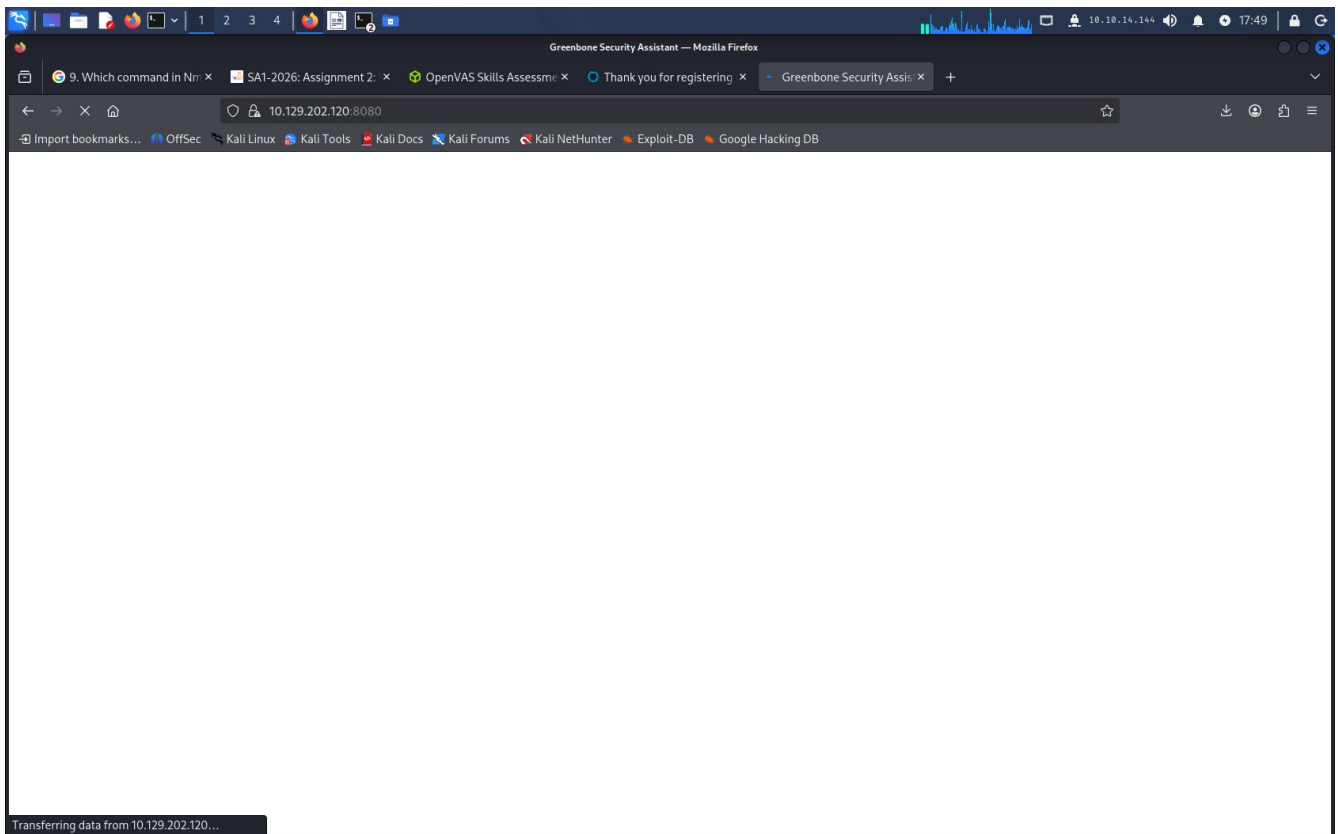
The scan will take up to 60 minutes to finish.

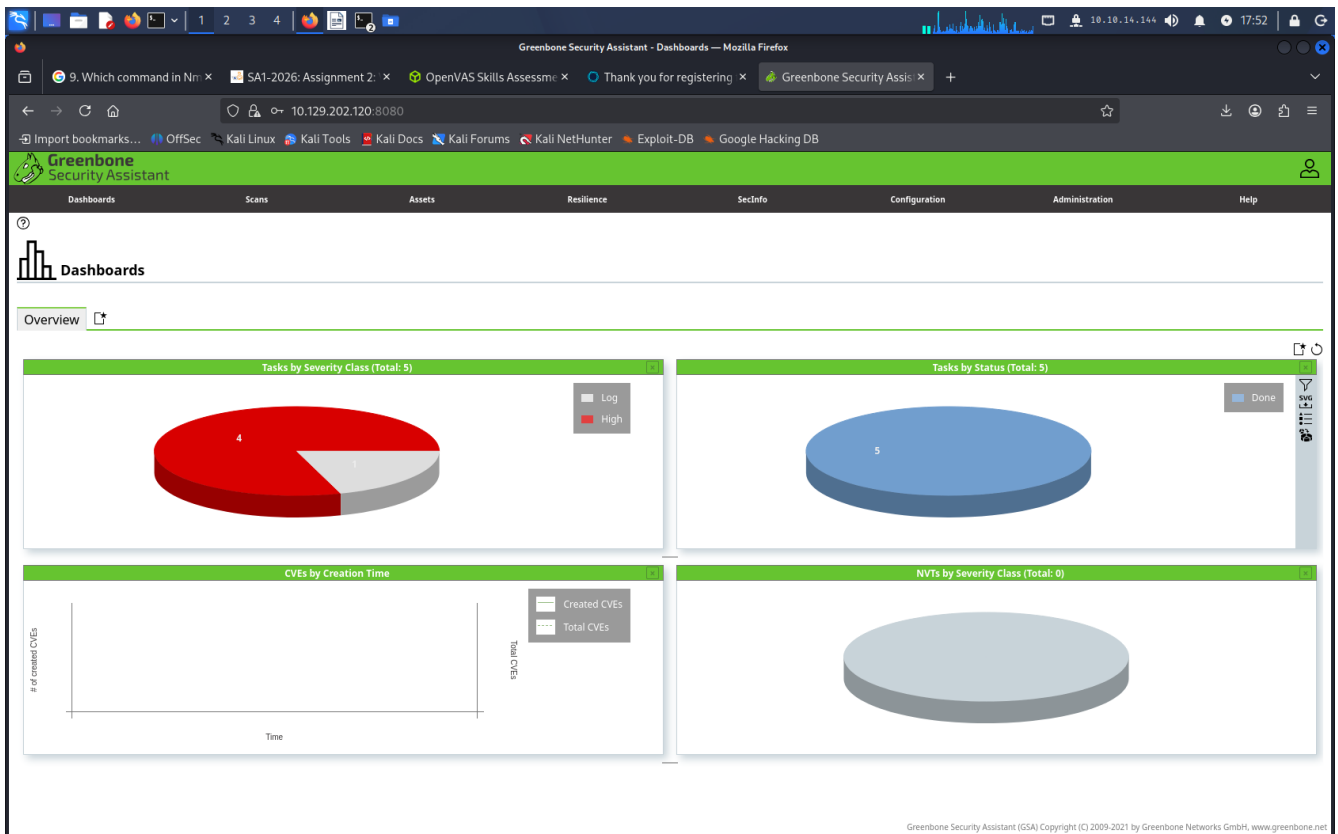
**Target:** 10.129.202.120

**Credentials are:** htb-student:HTB\_@cademy\_student!

**What type of operating system is the Linux host running? (one word)**

*Ubuntu*





Greenbone Security Assistant - Report Details — Mozilla Firefox

10.129.202.120:8080/report/2bf466b5-627d-4659-bea6-1758b43235b1

Greenbone Security Assistant

Dashboards Scans Assets Resilience SecInfo Configuration Administration Help

Filter

Report: Sat, Feb 12, 2022 10:01 PM UTC Done

ID: 2bf466b5-627d-4659-bea6-1758b43235b1 Created: Sun, Feb 13, 2022 1:01 AM UTC Modified: Sun, Feb 13, 2022 1:42 AM UTC Owner: htb-student

| Information             | Results (4 of 141) | Hosts (1 of 1)                      | Ports (2 of 6) | Applications (7 of 7) | Operating Systems (1 of 1) | CVEs (1 of 1)   | Closed CVEs (0 of 0) | TLS Certificates (0 of 0) | Error Messages (0 of 0) | User Tags (0) |
|-------------------------|--------------------|-------------------------------------|----------------|-----------------------|----------------------------|-----------------|----------------------|---------------------------|-------------------------|---------------|
| <b>Operating System</b> |                    | <b>CPE</b>                          |                | <b>Hosts</b>          |                            | <b>Severity</b> |                      |                           |                         |               |
| Ubuntu 18.04            |                    | cpe:/o:canonical:ubuntu_linux:18.04 |                | 1                     |                            | 10.0 (High)     |                      |                           |                         |               |

(Applied filter: apply\_overrides=0 levels=html rows=100 min\_qpd=70 first=1 sort=reverse=severity)

Greenbone Security Assistant (GSA) Copyright (C) 2009-2021 by Greenbone Networks GmbH, www.greenbone.net

## What type of FTP vulnerability is on the Linux host? (Case Sensitive, four words)

### Anonymous FTP Login Reporting

The screenshot displays the Greenbone Security Assistant (GSA) interface in a Mozilla Firefox browser. The address bar shows the URL: `10.129.202.120:8080/report/2bf466b5-627d-4659-bea6-1758b43235b1`. The interface features a green header bar with the GSA logo and navigation tabs: Dashboards, Scans, Assets, Resilience, SecInfo, Configuration, Administration, and Help. Below the header, a table lists various reports, with 'Anonymous FTP Login Reporting' selected. The report details are shown in a sidebar on the left, including a summary, detection result, insight, and impact.

**Summary**  
Reports if the remote FTP Server allows anonymous logins.

**Detection Result**  
It was possible to login to the remote FTP service with the following anonymous account(s):  
`anonymous;anonymous@example.com`  
`ftp;anonymous@example.com`  
Here are the contents of the remote FTP directory listing:  
Account "anonymous":  
`drwxr-xr-x 2 ftp ftp 4096 Feb 07 01:10 pub`  
Account "ftp":  
`drwxr-xr-x 2 ftp ftp 4096 Feb 07 01:10 pub`

**Insight**  
A host that provides an FTP service may additionally provide Anonymous FTP access as well. Under this arrangement, users do not strictly need an account on the host. Instead the user typically enters 'anonymous' or 'ftp' when prompted for username. Although users are commonly asked to send their email address as their password, little to no verification is actually performed on the supplied data.  
Remark: NIST don't see 'configuration issues' as software flaws so the referenced CVE has a severity of 0.0. The severity of this VT has been raised by Greenbone to still report a configuration issue on the target.

**Detection Method**  
Details: `Anonymous FTP Login Reporting` `OID: 1.3.6.1.4.1.25623.1.0.900600`  
Version used: 2021-10-20T00:00:29Z

**Impact**  
Based on the files accessible via this anonymous FTP login and

## What is the IP of the Linux host targeted for the scan?

172.16.16.160

Greenbone Security Assistant - Report Details — Mozilla Firefox

10.129.202.120:8080/report/2bf466b5-627d-4659-bea6-1758b43235b1

Greenbone Security Assistant

Dashboards Scans Assets Resilience SecInfo Configuration Administration Help

Report: Sat, Feb 12, 2022 10:01 PM UTC [Done](#) ID: 2bf466b5-627d-4659-bea6-1758b43235b1 Created: Sun, Feb 13, 2022 1:01 AM UTC Modified: Sun, Feb 13, 2022 1:42 AM UTC Owner: htb-student

Information Results **Hosts** (1 of 1) Ports (2 of 8) Applications (7 of 7) Operating Systems (1 of 1) CVEs (1 of 1) Closed CVEs (0 of 0) TLS Certificates (0 of 0) Error Messages (0 of 0) User Tags (0)

| IP Address   | Hostname | OS | Ports | Apps | Distance | Auth | Start                         | End                           | High | Medium | Low | Log | False Positive | Total | Severity ▼  |
|--------------|----------|----|-------|------|----------|------|-------------------------------|-------------------------------|------|--------|-----|-----|----------------|-------|-------------|
| 172.16.16.16 |          |    | 2     | 7    |          | ✓    | Sun, Feb 13, 2022 1:03 AM UTC | Sun, Feb 13, 2022 1:42 AM UTC | 1    | 2      | 1   | 0   | 0              | 4     | 10.0 (High) |

(Applied filter: apply\_overrides=0 levels=html rows=100 min\_qpd=70 first=1 sort=reverse=severity)

Greenbone Security Assistant (GSA) Copyright (C) 2009-2021 by Greenbone Networks GmbH, www.greenbone.net

**What vulnerability is associated with the HTTP server? (Case-sensitive)**

*Cleartext Transmission of Sensitive Information via HTTP*

Greenbone Security Assistant - Report Details — Mozilla Firefox

10.129.202.120:8080/report/2bf466b5-627d-4659-bea6-1758b43235b1

Greenbone Security Assistant

Dashboards Scans Assets Resilience SecInfo Configuration Administration Help

Report: Sat, Feb 12, 2022 10:01 PM UTC

ID: 2bf466b5-627d-4659-bea6-1758b43235b1 Created: Sun, Feb 13, 2022 1:01 AM UTC Modified: Sun, Feb 13, 2022 1:42 AM UTC Owner: htb-student

Information Results (4 of 147) Hosts (1 of 1) Ports (2 of 8) Applications (7 of 7) Operating Systems (1 of 1) CVEs (1 of 1) Closed CVEs (0 of 0) TLS Certificates (0 of 0) Error Messages (0 of 0) User Tags (0)

Vulnerability

|                                                                 | Severity     | QoD  | Host IP       | Name | Location    | Created                       |
|-----------------------------------------------------------------|--------------|------|---------------|------|-------------|-------------------------------|
| Report outdated / end-of-life Scan Engine / Environment (local) | 10.0 (High)  | 97 % | 172.16.16.160 |      | general/tcp | Sun, Feb 13, 2022 1:03 AM UTC |
| Anonymous FTP Login Reporting                                   | 4.4 (Medium) | 80 % | 172.16.16.160 |      | 21/tcp      | Sun, Feb 13, 2022 1:09 AM UTC |
| Cleartext Transmission of Sensitive Information via HTTP        | 4.4 (Medium) | 80 % | 172.16.16.160 |      | 80/tcp      | Sun, Feb 13, 2022 1:21 AM UTC |
| TCP timestamps                                                  | 2.8 (Low)    | 80 % | 172.16.16.160 |      | general/tcp | Sun, Feb 13, 2022 1:15 AM UTC |

(Applied filter: apply\_overrides=0 levels=html rows=100 min\_qod=70 first=1 sort=reverse-severity)

Greenbone Security Assistant (GSA) Copyright (C) 2009-2021 by Greenbone Networks GmbH, www.greenbone.net

OpenVAS Skills Assessment | Hack The Box Academy — Mozilla Firefox

academy.hackthebox.com/app/module/108/section/1516

HTB ACADEMY Dashboard Library Resources

What type of operating system is the Linux host running? (one word)

Authenticate to 10.129.202.120 (ACADEMY-VA-SCAN02), with user "htb-student" and password "HTB\_@cademy\_student!"

ubuntu

Question 2

What type of FTP vulnerability is on the Linux host? (Case Sensitive, four words)

Anonymous FTP Login Reporting

Question 3

What is the IP of the Linux host targeted for the scan?

172.16.16.160

Question 4

What vulnerability is associated with the HTTP server? (Case-sensitive)

Cleartext Transmission of Sensitive Information via HTTP

Previous Section 16 / 17 Next

Getting Started Mark complete & next